TryHackMe: Offensive Security Intro – CTF Write-up

Difficulty:

Easy

Objective:

To discover hidden web pages on a vulnerable banking application using brute-force directory scanning.

Task Summary:

This room simulates an insecure web application called **FakeBank**. As a regular user, we are asked to find vulnerabilities — specifically hidden URLs — using a tool called dirb.

Steps Performed

☑ Step 1: Briefing and Setup

We are logged in as **Mrs. G. Benjamin** (regular user) in the FakeBank app.

Our mission is to find sensitive endpoints not meant to be accessed by regular users.

💻 Step 2: Launch Terminal and Use

dirb

We opened the terminal and used the following command to brute-force discover hidden directories:

dirb http://fakebank.thm

- The tool used: **dirb**
- Wordlist used: /usr/share/dirb/wordlists/common.txt

🔎 Step 3: Output Analysis

dirb scanned **4609 words** and found two hidden paths:

1. http://fakebank.thm/bank-deposit (200 OK)
2. http://fakebank.thm/images (301 Redirect)

These were discovered by testing common URL paths using a brute-force method.

☑ Answers

Q: What are the 2 hidden URLs found?

- ✓ http://fakebank.thm/bank-deposit
- ✓ http://fakebank.thm/images

🧰 Tools Used

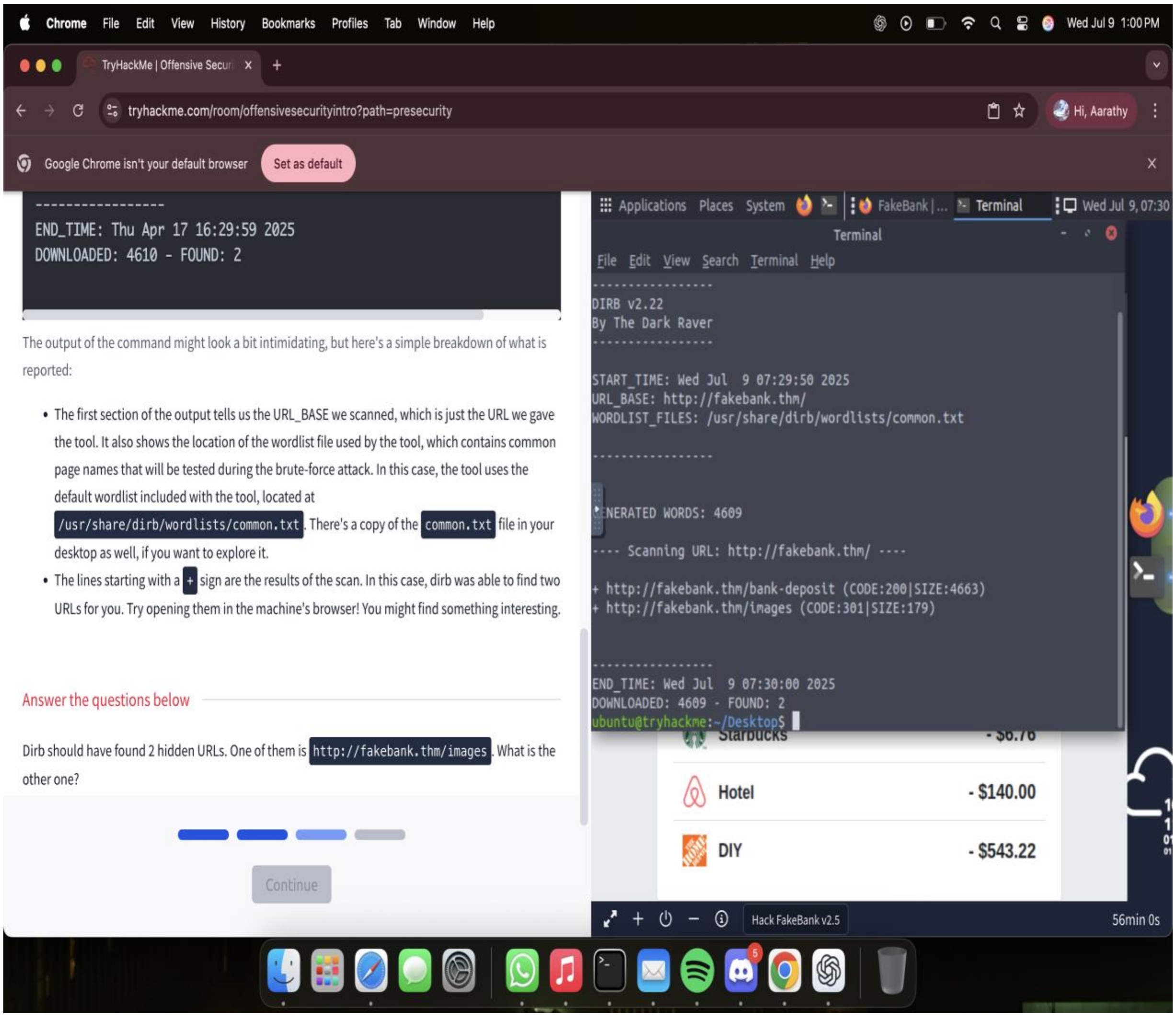
- **dirb** – for brute-force directory enumeration
- **Wordlist** – /usr/share/dirb/wordlists/common.txt
- **Browser & Terminal** – to interact with the target machine

🧠 Key Takeaways

- Applications sometimes expose sensitive pages via predictable URLs.
- Brute-forcing directories with tools like dirb helps discover hidden or admin-only areas.

- This kind of enumeration is a basic and crucial part of **offensive security** and **web app penetration testing**.

In this task, I explored the fundamentals of offensive security through a practical TryHackMe challenge. The scenario involved analyzing a vulnerable banking web application called FakeBank, where the goal was to identify hidden URLs using brute-force techniques. By leveraging the dirb tool with a common wordlist, I successfully discovered sensitive endpoints that were not intended for regular users. This activity helped me understand how attackers can enumerate and exploit hidden resources in a web application, reinforcing the importance of secure URL management and defensive strategies in web development.


Chrome File Edit View History Bookmarks Profiles Tab Window Help
Wed Jul 9 1:00 PM
TryHackMe | Offensive Secur
tryhackme.com/room/offensivesecurityintro?path=presecurity
Hi, Aarathy
Google Chrome isn't your default browser
Set as default

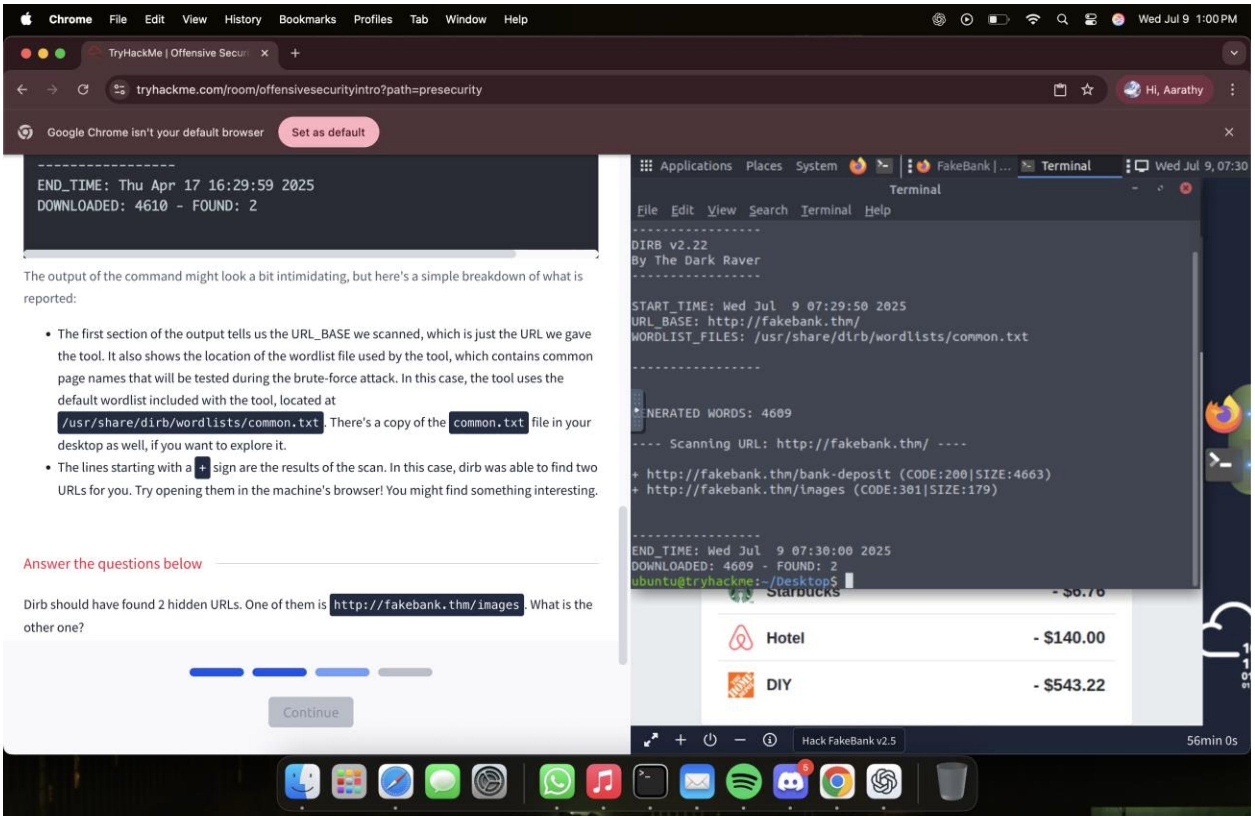
END_TIME: Thu Apr 17 16:29:59 2025
DOWNLOADED: 4610 - FOUND: 2
The output of the command might look a bit intimidating, but here's a simple breakdown of what is reported:
• The first section of the output tells us the URL_BASE we scanned, which is just the URL we gave the tool. It also shows the location of the wordlist file used by the tool, which contains common page names that will be tested during the brute-force attack. In this case, the tool uses the default wordlist included with the tool, located at /usr/share/dirb/wordlists/common.txt. There's a copy of the common.txt file in your desktop as well, if you want to explore it.
• The lines starting with a + sign are the results of the scan. In this case, dirb was able to find two URLs for you. Try opening them in the machine's browser! You might find something interesting.
Answer the questions below
Dirb should have found 2 hidden URLs. One of them is http://fakebank.thm/images. What is the other one?
Continue
Applications Places System
FakeBank | ...
Terminal
Wed Jul 9, 07:30
File Edit View Search Terminal Help

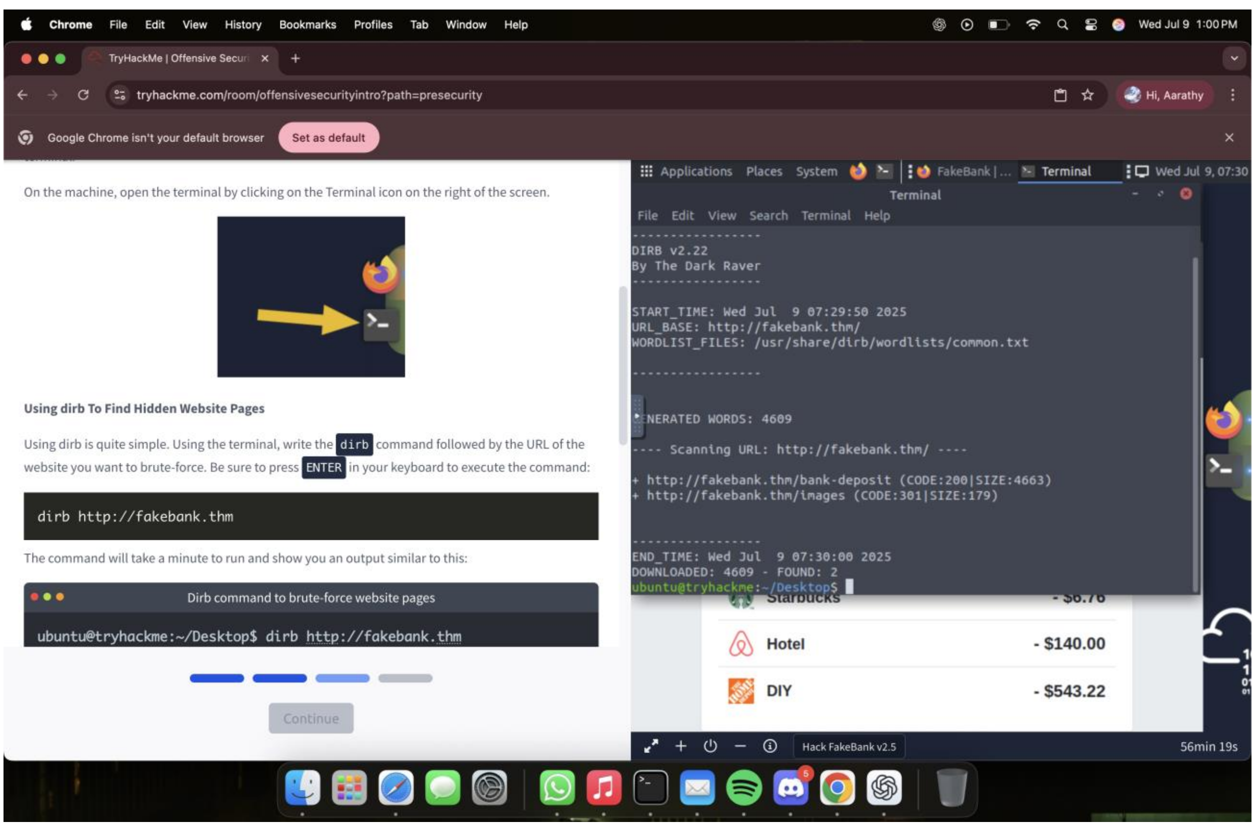
DIRB v2.22
By The Dark Raver

START_TIME: Wed Jul 9 07:29:50 2025
URL_BASE: http://fakebank.thm/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

ENERATED WORDS: 4609
---- Scanning URL: http://fakebank.thm/ ----
+ http://fakebank.thm/bank-deposit (CODE:200|SIZE:4663)
+ http://fakebank.thm/images (CODE:301|SIZE:179)

END_TIME: Wed Jul 9 07:30:00 2025
DOWNLOADED: 4609 - FOUND: 2
ubuntu@tryhackme:~/Desktop$
Starbucks - $6.76
Hotel - $140.00
DIY - $543.22
Hack FakeBank v2.5
56min 0s


Chrome File Edit View History Bookmarks Profiles Tab Window Help
Wed Jul 9 1:00 PM
TryHackMe | Offensive Secur
tryhackme.com/room/offensivesecurityintro?path=presecurity
Hi, Aarathy
Google Chrome isn't your default browser
Set as default
END_TIME: Thu Apr 17 16:29:59 2025
DOWNLOADED: 4610 - FOUND: 2
The output of the command might look a bit intimidating, but here's a simple breakdown of what is reported:
• The first section of the output tells us the URL_BASE we scanned, which is just the URL we gave the tool. It also shows the location of the wordlist file used by the tool, which contains common page names that will be tested during the brute-force attack. In this case, the tool uses the default wordlist included with the tool, located at /usr/share/dirb/wordlists/common.txt. There's a copy of the common.txt file in your desktop as well, if you want to explore it.
• The lines starting with a + sign are the results of the scan. In this case, dirb was able to find two URLs for you. Try opening them in the machine's browser! You might find something interesting.
Answer the questions below
Dirb should have found 2 hidden URLs. One of them is http://fakebank.thm/images. What is the other one?
Continue
Applications Places System FakeBank | ... Terminal Wed Jul 9, 07:30
Terminal
File Edit View Search Terminal Help
DIRB v2.22
By The Dark Raver
START_TIME: Wed Jul 9 07:29:50 2025
URL_BASE: http://fakebank.thm/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
ENERATED WORDS: 4609
---- Scanning URL: http://fakebank.thm/ ----
+ http://fakebank.thm/bank-deposit (CODE:200|SIZE:4663)
+ http://fakebank.thm/images (CODE:301|SIZE:179)
END_TIME: Wed Jul 9 07:30:00 2025
DOWNLOADED: 4609 - FOUND: 2
ubuntu@tryhackme:~/Desktop$
Hotel - $140.00
DIY - $543.22
Hack FakeBank v2.5
56min 0s


Chrome File Edit View History Bookmarks Profiles Tab Window Help
Wed Jul 9 1:00 PM
TryHackMe | Offensive Secur
tryhackme.com/room/offensivesecurityintro?path=presecurity
Hi, Aarathy
Google Chrome isn't your default browser
Set as default
On the machine, open the terminal by clicking on the Terminal icon on the right of the screen.
Using dirb To Find Hidden Website Pages
Using dirb is quite simple. Using the terminal, write the dirb command followed by the URL of the website you want to brute-force. Be sure to press ENTER in your keyboard to execute the command:
dirb http://fakebank.thm
The command will take a minute to run and show you an output similar to this:
Dirb command to brute-force website pages
ubuntu@tryhackme:~/Desktop$ dirb http://fakebank.thm
Continue
Applications Places System FakeBank | ... Terminal Wed Jul 9, 07:30
Terminal
File Edit View Search Terminal Help
DIRB v2.22
By The Dark Raver
START_TIME: Wed Jul 9 07:29:50 2025
URL_BASE: http://fakebank.thm/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
ENERATED WORDS: 4609
---- Scanning URL: http://fakebank.thm/ ----
+ http://fakebank.thm/bank-deposit (CODE:200|SIZE:4663)
+ http://fakebank.thm/images (CODE:301|SIZE:179)
END_TIME: Wed Jul 9 07:30:00 2025
DOWNLOADED: 4609 - FOUND: 2
ubuntu@tryhackme:~/Desktop$
Hotel - $140.00
DIY - $543.22
Hack FakeBank v2.5
56min 19s